

CyberDefense Pro 2.0

2.3.2 Security Control Categories Facts

This lesson covers the following topics:

- Security controls
- Security control categories
- Standards and frameworks
- Security control testing

Security Controls

It is common to identify that many security controls are deployed quickly, often as a reactive response to newly identified threats. In the early years of cyber defense, this approach was practical. For example, firewalls provided quick and effective protection and were straightforward to deploy; the level of protection a simple firewall provided was much more comprehensive than what is needed today. As viruses and worms began to infect computer systems through the 1990s, organizations deployed antivirus software on workstations and servers. This approach was simple, effective, and solely focused on preventative measures. At the time, this approach worked.

As modern cyber threats have become increasingly sophisticated, the ability to implement relatively simple controls with high levels of protection is becoming much rarer. Current infrastructures are complicated and require layered security controls deployed structured and systematically. Additionally, in the early years of computing, organizations were far less dependent on technology resources, and technology risks were less severe.

Security Control Categories

Security controls reduce the risk of loss and damage to an organization, including its computer systems. The National Institute of Standards and Technology (NIST) has designed methods for classifying security controls. In this first method, each control is organized into different classes based on the dominant characteristics of the control. The significance of these classes is that they are referenced when measuring how effectively assets are protected. The objective is to implement controls in each of the three classes. The three categories are as follows:

Security controls are categorized by function. These functional control types are:

Category	Control
Managerial	Managerial controls provide oversight of the information system. Examples include: • Security assessment • Risk identification • Evaluation of controls • Planning and selection of controls
Operational	Operational controls are usually implemented by people instead of systems. Operational controls include: • Security guards • Employee training • Security procedures
Technical	Technical controls are implemented as a system (hardware, software, or firmware). They may also be described as logical controls. Technical controls include: • Network segmentation • Access control lists (ACLs) • IPS devices • Firewalls • Antivirus software



As of rev 4, NIST 800-53 removes these class designations from the control families. It describes technical, operational, and management as properties of individual controls within a family instead. They are included to help familiarize learners with the basic concepts presented in 800-53 and be aware that terminology usage and practice are always evolving. Many organizations and publications still use this terminology.

Standards and Frameworks

A modern approach to security requires integrating several different types of controls, not only preventative but also detective, corrective, compensating, and responsive. While a single security

control is not impenetrable, layering various controls can help to delay an attack. Several standards and frameworks exist to help practitioners better understand practical control types. Some examples include:

- NIST Special Publication 800-53 Security and Privacy Controls for Federal Information Systems and Organizations (<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>)
- NIST Special Publication 800-171 Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations (<https://csrc.nist.gov/pubs/sp/800/171/r2/upd1/final>)
- ISO 27001 is a proprietary standard (<https://www.iso.org/standard/27001>)
- CIS Controls (<https://www.cisecurity.org/controls>)

The National Institute of Standards and Technology (NIST) Special Publications discussed in this course are available at csrc.nist.gov/publications/sp . There is no formal requirement to read them as part of exam preparation. However, they are referenced to help provide a deeper understanding of the various topics.

Security Control Testing

Security control testing involves evaluating an organization's security controls to ensure they function as intended and effectively protect against threats. Security control testing can include:

- Vulnerability assessments
- Penetration testing
- Security audits

The results of these tests can be used to improve security controls and to address any issues that may have been identified before a breach can occur.

Copyright © CompTIA, Inc. All rights reserved.